Reporting and Stakeholder Communication

Reporting is one of the most important skills in penetration testing. Even if you find critical vulnerabilities, they have no value if stakeholders cannot understand them or act on them. Below is a clear learning roadmap for mastering reporting and stakeholder communication.

Report Structure

A good penetration testing report usually follows standards like the **Penetration Testing Execution Standard (PTES)**.

1. Executive Summary (For Management)
   - High-level overview
   - Business impact
   - Risk level
   - Key recommendations

Example:

The assessment identified **3 critical vulnerabilities** that could allow attackers to access sensitive customer data. Immediate remediation is recommended to reduce the risk of data breaches.

2. Scope and Methodology

   Explain:
   - Scope of testing
   - Tools used
   - Testing approach

   Example:
   - External network testing
   - Web application testing
   - Methodology based on PTES

3. Findings

   Each vulnerability should include:

Field	Description	Example
Title	Name of vulnerability	SQL Injection
Severity	Critical / High / Medium / Low	Critical

Description	What the vulnerability is	User input is not properly sanitized.
Impact	What can attacker could do	Attackers can extract database contents.
Proof of Concept	Screenshots, payloads	' OR 1=1--
Remediation	How to fix it	Use parameterized queries and Implement input validation

Table 1: Findings content with example

4. Risk Rating
   Use industry standards like
   - **CVSS (Common Vulnerability Scoring System)**
   - Internal severity models

Example scale:

Score	**Risk**
9-10	Critical
7-8.9	High
4-6.9	Medium
0-3.9	Low

Table 2: Risk Rating

5. Remediation Plan
   Provide clear action items.

Vulnerability	**Fix**
SQL Injection	Use prepared statements
Outdated Software	Patch to latest version
Weak Password Policy	Enforce strong passwords

Table 3: Remediation Plan

Non-technical briefs for managers and detailed reports for developers

When reporting vulnerabilities, you must adapt the same finding for different audiences. Managers want business impact, while developers need technical detail to fix the issue. Here's how to craft both.

❖ **Non-Technical Brief**

Managers usually do not care about payloads, ports, or commands**.** They want to know,

- What is the risk?
- What is the business impact?
- How urgent is the fix?

Example: Manager Brief

Issue: Database Exposure Risk

Summary:
A weakness in the login system could allow attackers to access the company database without proper authorization.

Business Impact:
If exploited, attackers could steal sensitive customer data such as usernames, passwords, and financial information. This could lead to regulatory penalties, reputational damage, and customer trust loss.

Risk Level: High

Recommended Action:
The development team should update the login system to properly validate user input and deploy the fix immediately.

- **Technical Report**
  Developers need exact technical details so they can reproduce and fix the issue.
  Include:
  - Vulnerability description
  - Affected component
  - Proof of Concept
  - Exploitation steps
  - Remediation guidance

Example: Developer Report

Vulnerability: SQL Injection in Login Form

Severity: High

Affected Endpoint:

/login.php

Description:
The application does not properly sanitize user input in the username parameter. This allows attackers to inject SQL queries.

Proof of Concept:
Username: ' OR 1=1--
Password: anything

Result:
Authentication bypass occurs, allowing access without valid credentials.

Impact:
Attackers can gain unauthorized access and potentially extract database data.

Remediation:

- Use parameterized queries (prepared statements)
- Implement input validation
- Apply ORM frameworks if possible

Use metrics like vulnerability count, exploit success rate, and time-to-remediate.

Using security metrics and KPIs helps stakeholders understand the overall security posture and progress over time. Instead of just listing vulnerabilities, metrics provide measurable insights for decision-making.

Below are three important metrics often used in penetration testing and vulnerability management.

- Vulnerability Count
  This metric shows the **total number of vulnerabilities discovered** during testing and how they are distributed by severity.

Example,

Severity	Count
Critical	2
High	5
Medium	9
Low	14

Table 4: Vulnerability Count

What it tells stakeholders

- How many weaknesses exist in the system
- The **overall risk exposure**
- Whether security posture is improving or worsening over time

Example Interpretation

- 2 Critical vulnerabilities require immediate remediation
- Most vulnerabilities are Medium/Low, meaning system hardening is needed

Managers can quickly understand risk level without reading technical details.

Exploit Success Rate

This metric measures how many vulnerabilities were actually exploitable during the penetration test.

Formula

Exploit Success Rate =

$$\frac{Successfully\ Exploited\ Vulnerabilities}{Total\ Vulnerabilities\ Tested} \times 100$$

Example

- Vulnerabilities discovered: **20**
- Successfully exploited: **8**

Exploit Success Rate= $\frac{8}{20} \times 100 =$ **40%**

What it tells stakeholders

- How dangerous the vulnerabilities are
- Whether they can realistically be abused by attackers

Example interpretation:

- High exploit rate (60–80%) → serious security weakness
- Low exploit rate (10–20%) → vulnerabilities exist but may require complex attack chains

❖ **Time-to-Remediate (TTR)**
This metric measures how long it takes to fix vulnerabilities after discovery.

Formula

TTR=Date Fixed−Date Reported

Example

Vulnerability	Reported	Fixed	TTR
SQL Injection	Jan 1	Jan 3	2 days
Outdated Server	Jan 1	Jan 10	9 days

Table 5: Example of Time-to-Remediate

Average TTR = **5.5 days**

What it tells stakeholders

- How quickly the organization responds to security issues
- Efficiency of the development/security team

Typical targets:

Severity	Recommended Fix Time
Critical	24–72 hours
High	1 week
Medium	2–4 weeks
Low	1–3 months

Table 6: Typical targets

PTES reporting guidelines for structure.

Studying the reporting guidance from Penetration Testing Execution Standard (PTES) helps you produce clear, structured penetration testing reports that both technical teams and management can understand. PTES divides reporting into specific sections to ensure findings are actionable and well-organized.

1. Executive Summary
   This section provides a **high-level overview** for managers and executives who may not have technical backgrounds.

   Include:
   - Purpose of the penetration test
   - Overall security posture
   - Key risks discovered
   - Business impact
   - Summary of recommendations

2. Scope and Engagement Overview
   Describe what was tested and how the testing was conducted.

   Include:
   - Systems tested
   - Networks, applications, or infrastructure
   - Testing dates
   - Allowed testing methods

3. Methodology
   Explain the testing process used to identify vulnerabilities.

   Typical phases include:
   - Intelligence Gathering
   - Threat Modelling
   - Vulnerability Analysis
   - Exploitation
   - Post-Exploitation
   - Reporting

4. Findings and Vulnerability Details
   This is the **core technical section** of the report.

   Each vulnerability should include:

Field	Description
Vulnerability Title	Name of issue
Severity	Critical / High / Medium / Low
Description	Explanation of the vulnerability
Impact	What an attacker could achieve
Proof of Concept	Steps or screenshots
Remediation	How to fix it

Table 7: Vulnerability Details

5. Risk Ratings
   PTES encourages using standardized scoring methods like:
   Common Vulnerability Scoring System (CVSS)

   Example scale:

Score	Severity
9-10	Critical
7-8.9	High
4-6.9	Medium
0-3.9	Low

Table 8: Risk Ratings

6. Remediation Recommendations
   Each vulnerability should include clear and actionable fixes.

   Example:

Vulnerability	Recommendation
SQL Injection	Use prepared statements
Outdated Software	Apply latest security patches
Weak Authentication	Implement multi-factor authentication

Table 9: Example of Recommendations

7. Metrics and Summary Statistics
   PTES reports often include metrics such as:
   - Total vulnerabilities discovered
   - Severity distribution
   - Exploit success rate
   - Time-to-remediate estimates

8. Appendix
   Optional supporting information such as:
   - Tool outputs
   - Screenshots
   - Payload examples
   - Logs
   - Network diagrams

SANS pentest report templates

Reviewing SANS-style penetration testing report templates helps you understand how professional security consultants structure reports for both executives and technical teams. These templates focus on clear structure, risk communication, and actionable remediation.

1. Cover Page
   The first page provides basic information about the engagement.

   Typical contents
   - Report title
   - Client organization
   - Test type (Web, Network, Red Team)
   - Testing date
   - Author / security team
   - Confidentiality statement

2. Table of Contents
   Lists all sections of the report

   Example:
   1. Executive Summary
   2. Scope of Engagement
   3. Methodology
   4. Vulnerability Findings
   5. Risk Analysis
   6. Remediation Recommendations
   7. Appendix

3. Executive Summar
   This section explains the overall security posture and business impact.

Include:

- Purpose of the assessment
- High-level findings
- Risk overview
- Key recommendations

4. Scope of Engagement
   Defines what was tested during the engagement.

5. Methodology
   This section explains **how the testing was conducted**.

   Typical phases include:
   - Reconnaissance
   - Vulnerability Scanning
   - Exploitation
   - Post-Exploitation
   - Reporting

6. Vulnerability Findings
   Each vulnerability is described in detail.

   Typical structure:

Field	Description
Title	Vulnerability name
Severity	Critical / High / Medium / Low
Description	Technical explanation
Impact	What attackers can do
Proof of Concept	Exploit steps
Remediation	Fix instructions

Table 10: Vulnerability Findings structure

7. Risk Analysis
   This section provides metrics and statistics.

   Example of summary table:

Severity	Count
Critical	2
High	4
Medium	7

Low	10

Table 11: Example of summary table

8. Remediation Recommendations
   Lists practical steps to fix vulnerabilities.

   Example:

Issue	Recommendation
SQL Injection	Use parameterized queries
Outdated software	Apply security patches
Weak authentication	Implement MFA

Table 12: Recommendations

9. Appendix
   Additional supporting data such as:
   - Tools used
   - Scan outputs
   - Screenshots
   - Payload examples
   - Attack diagrams

Analyze sample reports from HackTheBox or TryHackMe

TryHackMe sample reports focus on **clear, structured penetration testing documentation** that explains vulnerabilities, business impact, and remediation. They follow a standard format with **summary, technical findings, and appendices**, ensuring both technical and non-technical stakeholders can understand the results. The reports emphasize **real-world impact, audience-based communication, and actionable fixes**, making them practical and industry-aligned

Tryhackme Room – Writing Pentest Reports

Figure 1: Completed the TryHackMe "Writing Pentest Reports" room

Summary

Reporting and stakeholder communication play a vital role in penetration testing, as they convert technical findings into clear and actionable insights. A well-structured report includes an executive summary, detailed findings, risk ratings, and remediation steps, ensuring that vulnerabilities are properly understood and prioritized. Following standards like PTES and SANS helps maintain consistency and professionalism in reporting.

Effective communication requires tailoring reports for different audiences. Non-technical stakeholders, such as managers, need a high-level overview focusing on business impact and risk, while developers require detailed technical information, including proof of concept and remediation guidance. This approach ensures that all stakeholders can understand and act on the findings appropriately.

Additionally, using metrics such as vulnerability count, exploit success rate, and time-to-remediate provides measurable insights into an organization's security posture. These metrics help track progress, prioritize fixes, and support decision-making. Overall, strong reporting ensures that vulnerabilities are not only identified but also effectively addressed to improve security.